Read team report: pentesting de My File Server 1 | Act 13

Miguel Angel Salazar Martinez | 183833

Universidad Politécnica de San Luis Potosi

01/10/2026

Ni más ni menos

Resumen Ejecutivo

En el marco de la evaluación de seguridad correspondiente al engagement de pruebas de penetración sobre la infraestructura de la organización, se llevó a cabo un análisis exhaustivo utilizando metodologías reconocidas de la industria, incluyendo las fases de reconocimiento, enumeración, explotación y post-explotación. El objetivo principal de este ejercicio fue identificar, documentar y evaluar el nivel de exposición del activo denominado My File Server 1, así como determinar el impacto potencial que una amenaza real podría generar sobre los activos críticos de la empresa. Los resultados obtenidos revelan un panorama de riesgo sumamente crítico que requiere atención inmediata por parte de la dirección.

Durante la fase de reconocimiento y enumeración, se identificó una superficie de ataque significativamente amplia. El análisis permitió detectar múltiples puertos abiertos y servicios en ejecución que, en su mayoría, presentaban configuraciones deficientes o inexistentes medidas de protección. Entre los hallazgos más relevantes, se encontró que los servicios de transferencia de archivos y acceso remoto no contaban con políticas de contraseñas robustas ni con mecanismos de autenticación multifactor. Esta debilidad estructural permitió a un actor malicioso obtener acceso a información sensible sin encontrar barreras técnicas significativas.

El vector de ataque principal se materializó a través del servicio FTP, donde fue posible identificar credenciales de acceso con una facilidad preocupante. La explotación exitosa de esta vulnerabilidad derivó en el establecimiento de una conexión desde la máquina de pruebas hacia el servidor corporativo, lo que permitió a los evaluadores adentrarse en el entorno interno de la organización. Una vez dentro, se ejecutaron técnicas de escalamiento de privilegios que culminaron con la obtención del control total del sistema, incluyendo el acceso a la cuenta de administrador (root). Este nivel de compromiso otorgó a los atacantes la capacidad de manipular, extraer o destruir información confidencial, así como de instalar mecanismos de persistencia que podrían pasar desapercibidos durante largos periodos.

Las implicaciones de estos hallazgos trascienden el ámbito meramente técnico. La combinación de credenciales expuestas, configuraciones inseguras y sistemas operativos sin parches de seguridad representa un riesgo inaceptable para la

continuidad del negocio. Un atacante con acceso root podría exfiltrar bases de datos completas, alterar registros financieros, interrumpir servicios críticos o incluso utilizar el servidor comprometido como plataforma para lanzar ataques hacia otras organizaciones. El impacto potencial incluye pérdidas económicas significativas derivadas de la recuperación de sistemas, sanciones regulatorias por incumplimiento de normativas de protección de datos, y un daño reputacional incalculable que afectaría la confianza de clientes, socios comerciales y accionistas.

La confianza es un pilar fundamental en las relaciones comerciales. La revelación de una brecha de seguridad de esta magnitud generaría dudas razonables entre nuestros socios estratégicos respecto a la solidez de nuestros controles internos. La percepción de que la organización no es capaz de salvaguardar la información confidencial podría traducirse en la pérdida de contratos, la imposición de condiciones más restrictivas en futuras negociaciones o, en el peor de los casos, el cese definitivo de colaboraciones clave para el sostenimiento operativo y financiero de la empresa.

Como recomendación principal, se establece la necesidad imperiosa de ejecutar un plan de remediación inmediato. En primer lugar, se debe proceder al cierre de puertos y la desactivación de servicios que no sean estrictamente indispensables para la operación del negocio. En segundo lugar, es mandatorio revisar y fortalecer las políticas de autenticación, implementando contraseñas robustas, rotación periódica de credenciales y, preferiblemente, autenticación multifactor para todos los accesos remotos y administrativos. En tercer lugar, se requiere un programa urgente de gestión de parches que garantice la actualización oportuna del sistema operativo y las aplicaciones críticas, mitigando así vulnerabilidades conocidas como la que permitió la escalada de privilegios en este ejercicio. Finalmente, se sugiere la implementación de monitoreo continuo y auditorías periódicas que permitan detectar y responder ante intentos de intrusión en tiempo real.

En conclusión, el estado actual de seguridad del servidor evaluado representa una amenaza crítica para la organización. La evidencia recolectada demuestra que un atacante con motivación y recursos limitados podría comprometer la totalidad de los activos alojados en dicho sistema. La dirección debe priorizar la asignación de recursos humanos, técnicos y financieros para cerrar las brechas identificadas a la

brevedad posible, evitando así consecuencias devastadoras que podrían poner en riesgo la viabilidad misma de la empresa.

Alcance

Esta evaluación de seguridad se limita al activo denominado My File Server 1, una máquina virtual que simula un servidor de archivos corporativo. La dirección IP identificada para este activo dentro de la red de laboratorio aislada es 192.168.56.104. La prueba se realizó bajo un enfoque de caja negra (black-box), lo que significa que yo no contaba con información previa sobre la configuración interna, credenciales de acceso, código fuente o posibles vulnerabilidades del sistema. El objetivo fue simular las condiciones de un atacante externo que únicamente conoce la existencia del servidor y su dirección de red.

Metodología

La evaluación se llevó a cabo siguiendo un enfoque estructurado y alineado con estándares reconocidos de la industria. Se tomó como referencia el Penetration Testing Execution Standard (PTES) para la organización general de las fases, y las guías de OWASP Web Security Testing Guide (WSTG) para las pruebas específicas sobre servicios web y aplicaciones. El proceso se dividió en las siguientes fases:

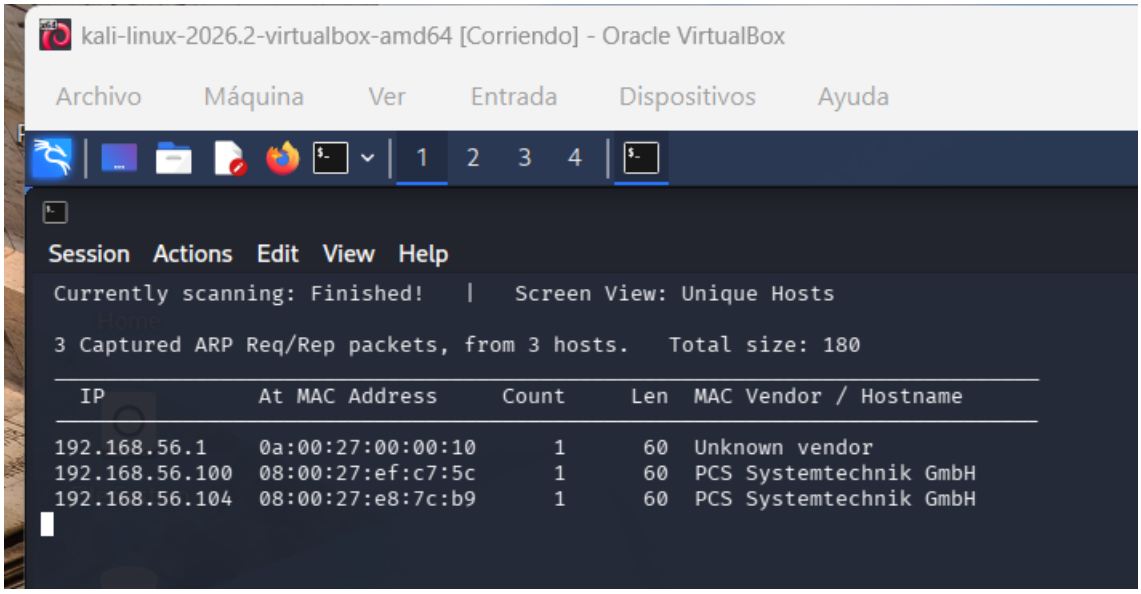
Reconocimiento: Identificación del activo en la red y descubrimiento de los servicios expuestos mediante técnicas de escaneo pasivo y activo.

Enumeración: Obtención de información detallada sobre los servicios identificados, incluyendo versiones, usuarios, recursos compartidos y posibles vectores de ataque.

Explotación: Aprovechamiento de las vulnerabilidades identificadas para obtener acceso inicial al sistema.

Post-Explotación: Escalada de privilegios, recolección de evidencia y evaluación del impacto real del compromiso.

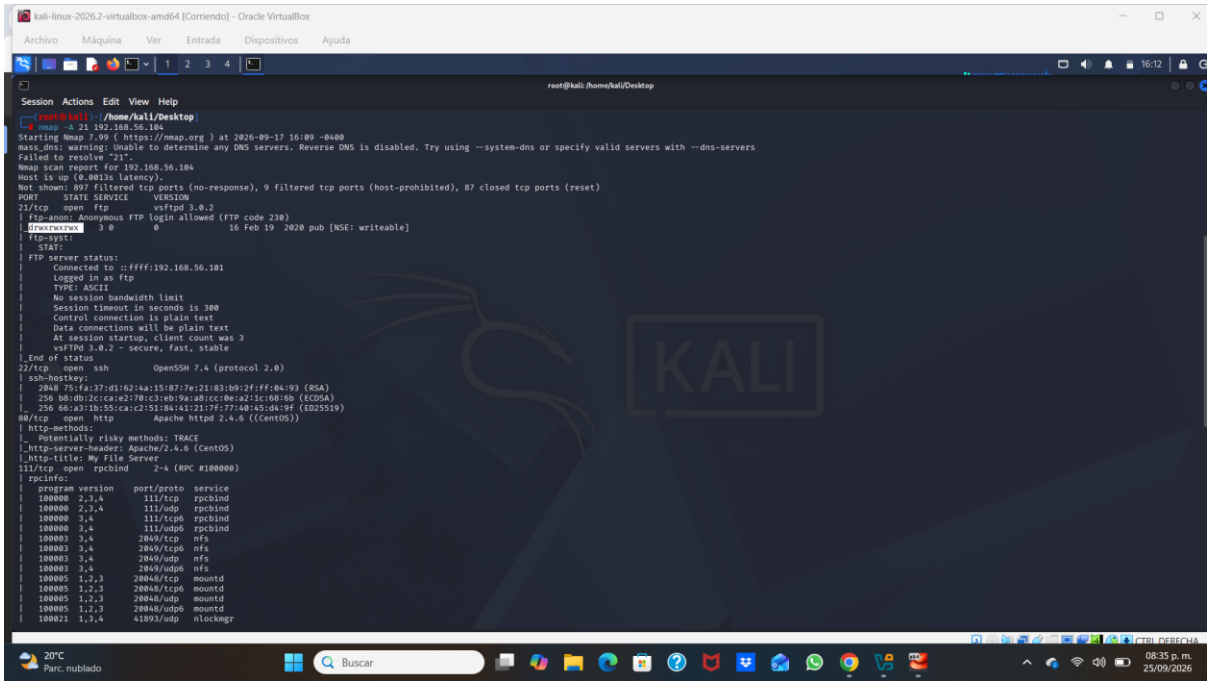
Reconocimiento



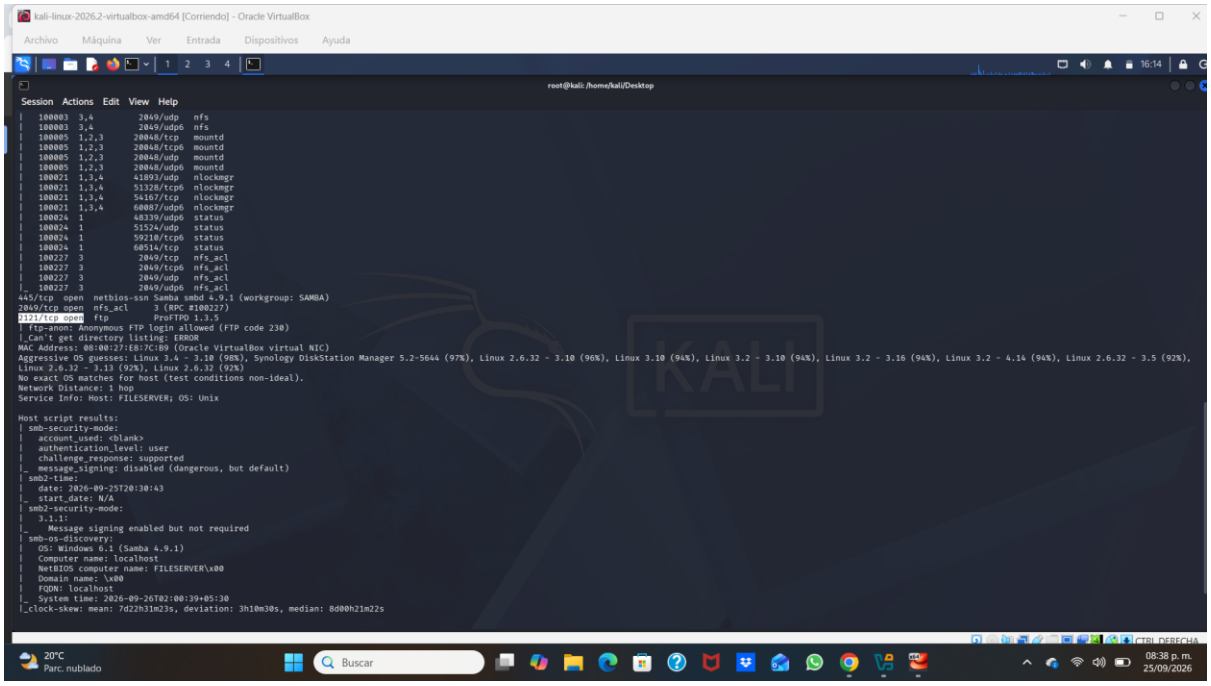
Para la parte de reconocimiento usamos el comando **netdiscover -r 192.168.56.0/24,** el parámetro -r para indicarle un rango de redes a escanear, y la /24 para indicarle que busque desde la ip 192.168.56.1 hasta la 192.168.56.254.



Continuando con la etapa de reconocimiento usamos el parametro de **nmap –p- 192.168.56.104 -sV,** en esta parte usamos nmap para hacer un escaneo de puertos con el –p- le indicamos a nmap que el escaneo será a todos los puertos sin excepción y con el –sV le indicamos que nos de la versión de los servicios que estén corriendo en estos puertos.



Dandole continuidad a la etapa de Reconocimiento podemos encontrar un escaneo más detallado de nuestra victima con el comando **nmap –A 192.168.56.104** que es un comando de escaneo muy agresivo que nos arroja bastante información interesante en esta podemos encontrar nuestro principal vector de ataque que se encuentra corriendo el servicio **ftp** en el puerto **21** con una versión de **vsftpd 3.0.2** y con libre albedrio prácticamente **drwxrwxrwx,** además de eso encontramos otras dos vulnerabilidades potenciales también a explotar, me refiero a los puertos ssh y http que se encuentran abiertos en los puertos 80 y 22 respectivamente.

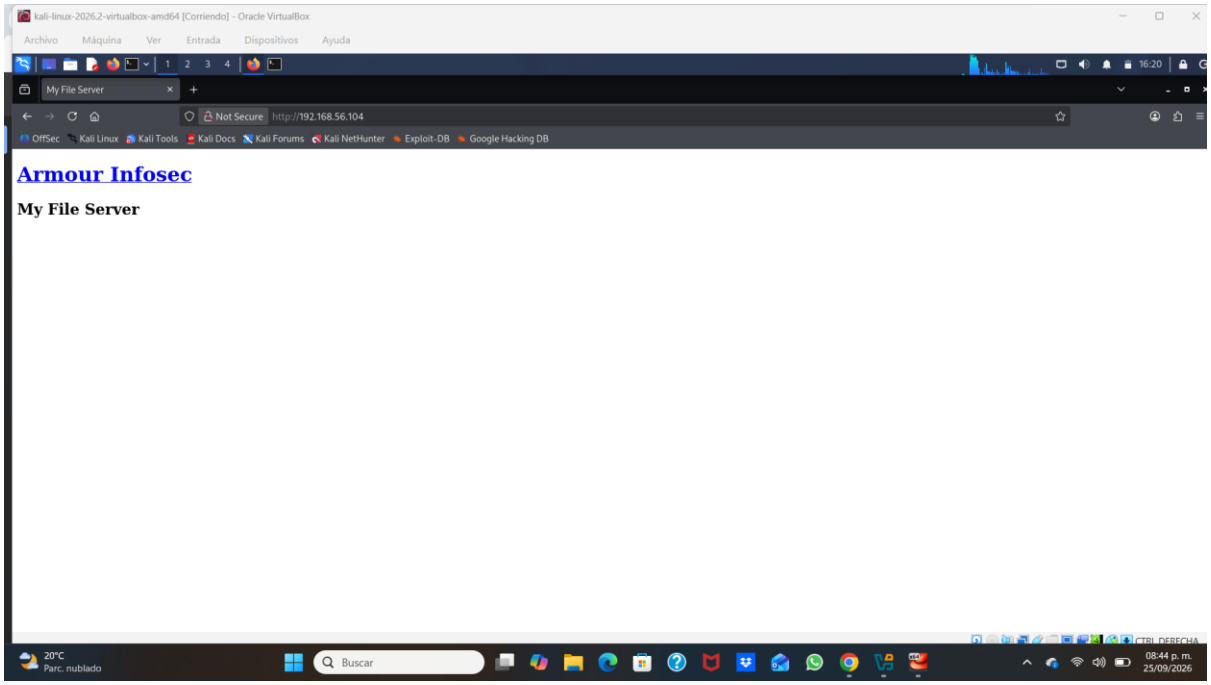


Siguiendo con el análisis exhaustivo de el reconocimiento de vulnerabilidades de nuestro activo, podemos encontrar que el SAMBA se encuentra corriendo y corriendo en el puerto 445, vulnerabilidad que también explotaremos más adelante.

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPd 3.0.2)
Name (192.168.56.104:kali):
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS.
530 Please login with USER and PASS.
ftp: Can't bind for data connection: Address already in use
ftp>
ftp> exit
221 Goodbye.

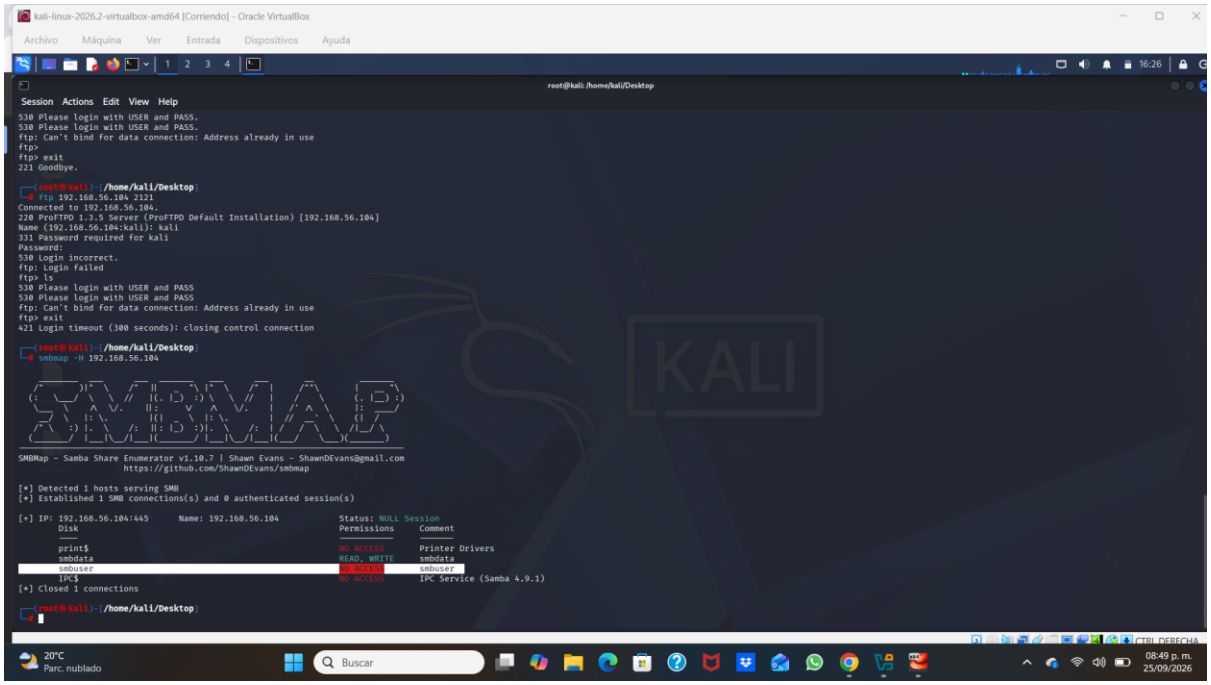
┌──(root㉿kali)-[/home/kali/Desktop]
└─# ftp 192.168.56.104 2121
Connected to 192.168.56.104.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.56.104]
Name (192.168.56.104:kali): kali
331 Password required for kali
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS
530 Please login with USER and PASS
ftp: Can't bind for data connection: Address already in use
ftp>
```

Como bien supimos el servicio ftp se encontraba abierto y con permisos de todo tipo entonces intentamos acceder y entrar por ahí, sin resultado alguno esto debido a que se solicita un usuario y una contraseña, con las cuales aún no contamos.



Entonces como parte del reconocimiento aun y sin victoria alguna al tratar de entrar por ftp, recordemos que el puerto 80 del servicio http también se encontraba abierto entonces entramos a la página web que se encuentra abierta en el puerto http y encontramos información un poco interesante, como que esta página es de alguien que está haciendo su primer servidor : (.

Enumeración

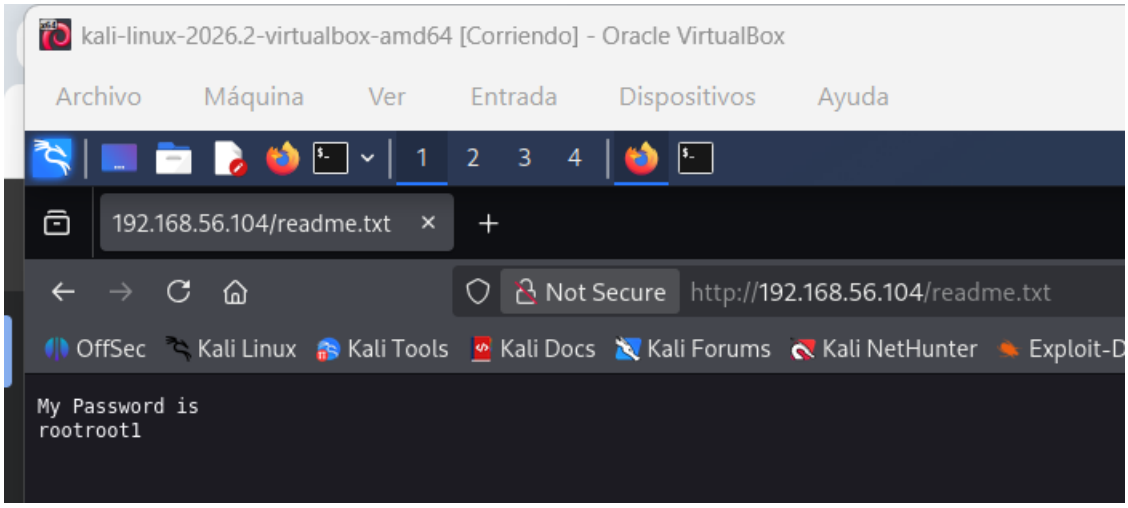


Recordando que el servicio de SAMBA smbd se encontraba abierto y corriendo entonces decidimos utilizar el comando **smbmap –H 192.168.56,** smbmap es una herramienta del servicio smb que lista recursos compartidos del host (-H) objetivo (192.168.56.104). En este caso nos arroja un usuario que es el “smbuser” que es el que explotaremos.



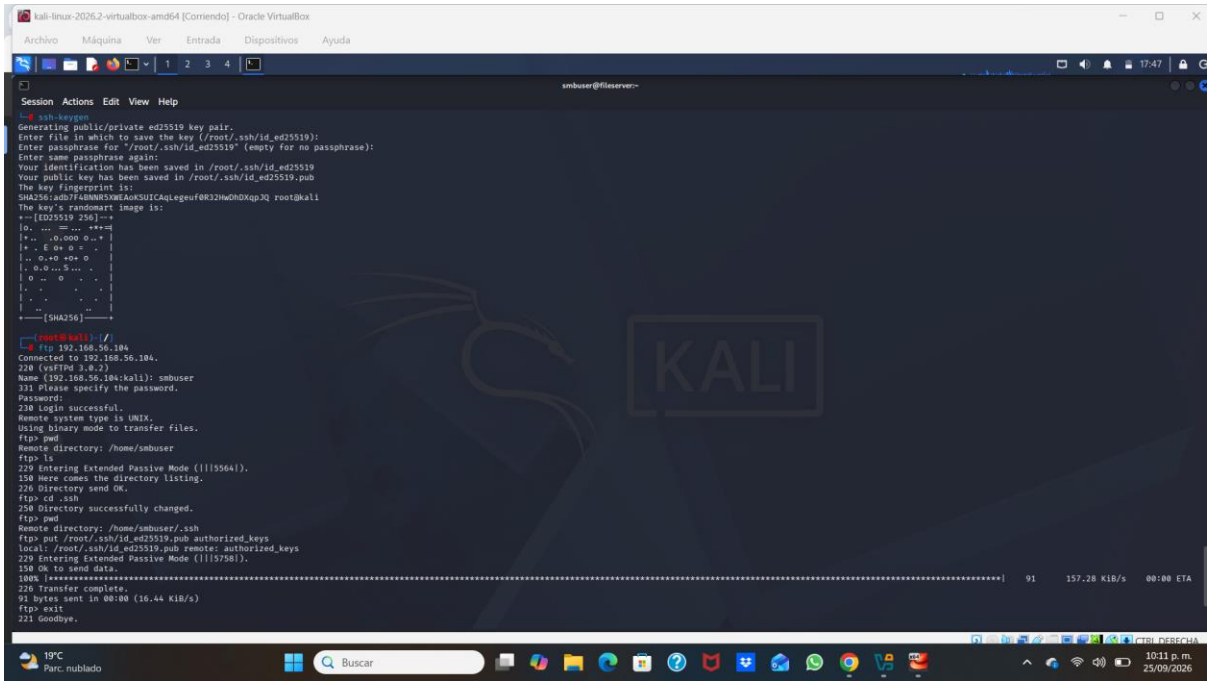
Continuando con la fase de enumeración y ya con el usuario descubieto desde la vulnerabilidad que encontramos con smbmap que nos revelo el smbuser, toco utilizar nikto –h 192.168.56.104, que es una herramienta que nos ayuda a descubrir vulnerabilidades de una web, nikto nos revelo bastantes cositas, algunas las conocíamos como el puerto (80) y la dirección ip, nos revela el server que se está

corriendo en el puerto que es el **Apache/2.4.6** pero más importante aún nos revela un archivo en la página web algo curioso, su nombre **readme.txt.**



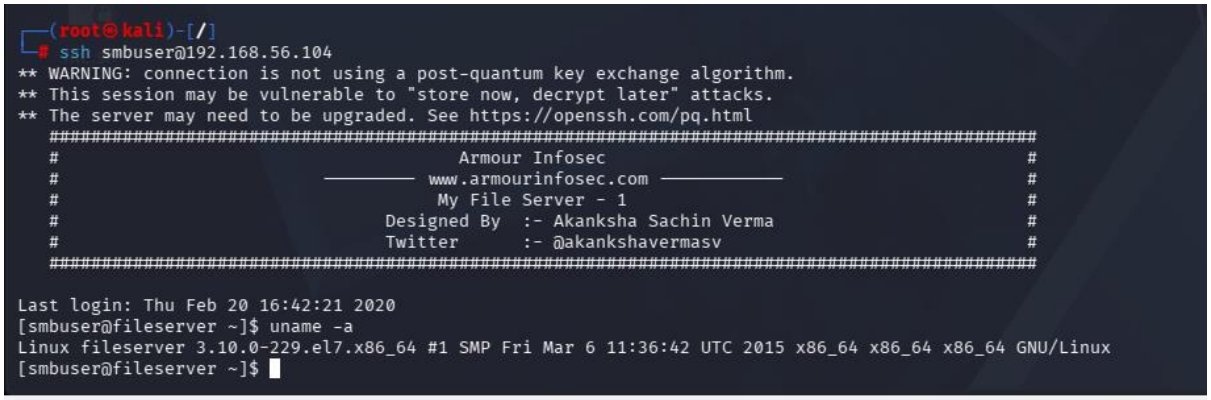
Al ejecutar la página web con el archivo que acabamos de descubrir (192.168.56.104/readme.txt) nos arroja la pieza clave para completar nuestro rompecabezas la password **rootroot1.**

Explotación



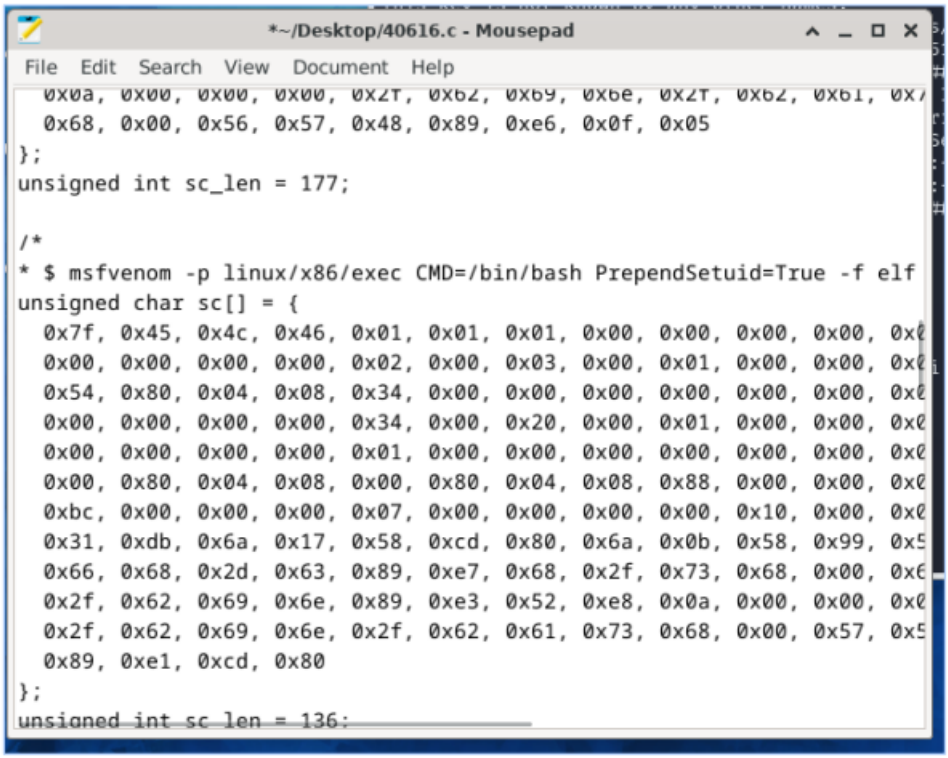
Comenzando con la fase más divertida el explota miento de todas esas vulnerabilidades descubiertas y ya documentadas, continuamos con la creación de nuestras claves ssh, nos interesa la publica la .pub que por defecto se guarda en

/root/.ssh. Necesitamos poner nuestra clave publica en el .ssh de la víctima que crearemos, para ello ocupamos un usuario con clave que ya descubrimos previamente el smbuser y su password rootroot1 con las que nos conectamos al ftp, donde creamos el directorio .ssh y ponemos nuestra clave publica ssh que previamente generamos.

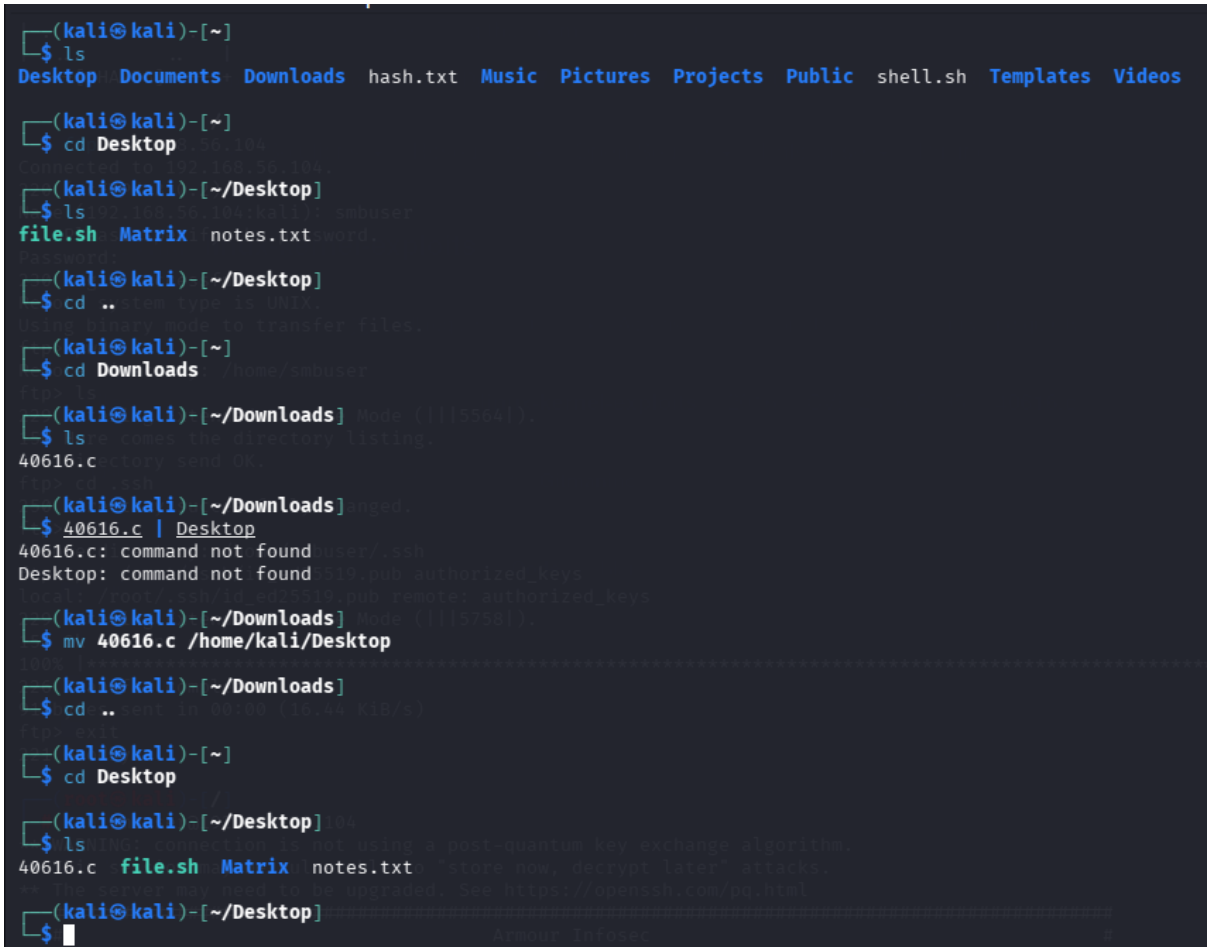


De esta forma nos conectamos remotamente por ssh, para poder ejecutar el siguiente comando **uname –a,** a este comando lo llamaria el peon que se volvio rey, porque nos arroja oro puro, y esto es porque nos arroja la versión del kernel de linux **3.10.0-229,** versión que cae en una de tantas que cuentan con la misma vulnerabilidad, una **condición de carrera**. Esta condición de carrera aprovecha un fallo en el kernel de linux que permite una escalada de privilegios desde un usuario sin ningun poder hasta el tan famoso root, dicha condicion de carrera se llama **Dirty COW.**

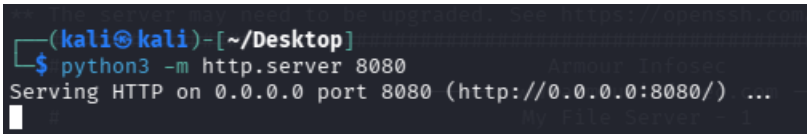
https://github.com/SecWiki/linux-kernel-exploits/blob/master/2016/CVE-2016-5195/40616.c



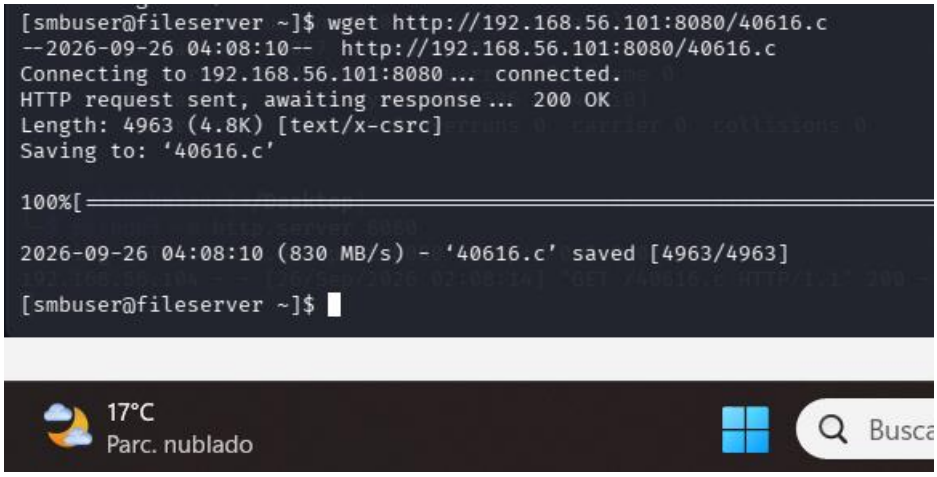
Navegando en git, encontramos un directorio que cuenta con las versiones de los kernels de linux que presentan esta falla y claramente está el kernel de la maquina víctima.



Descargamos el archivo 40616.c que contiene esta condición de carrera para nuestra maquina objetivo, y lo movemos al Desktop.



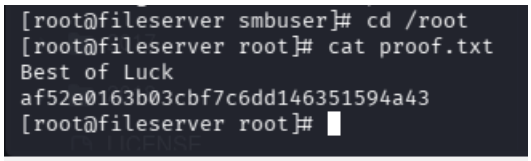
Levantamos el servidor http con python desde nuestro Desktop.



Escalada de Privilegios (Post-Explotación)



Ejecutamos el archivo 40616.c para ejecutar nuestra COW y listo somos el usuario root



Lo siguiente a este paso es empezar a documentar todo y empezar a robar, borrar y o encryptar archivos.

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
01	Credenciales en texto plano (readme.txt)	Alta	Captura de pantalla del archivo readme.txt encontrado con la contraseña rootroot1.	Un atacante obtiene acceso al FTP y puede leer/descargar archivos internos.	Eliminar archivos con información sensible del servidor web. Implementar un gestor de contraseñas.
02	Escritura en directorio de usuario a través de FTP	Alta	La sesión FTP permite subir archivos al directorio personal del usuario smbuser.	Permite a un atacante con credenciales FTP subir una clave pública SSH y obtener una shell remota.	Configurar el servidor FTP con permisos restrictivos. Deshabilitar la escritura en directorios sensibles si no es estrictamente necesario.
03	Sistema operativo sin parches (Dirty COW)	Crítica	El comando uname -r muestra un kernel 3.10.0-229.	Permite a un usuario local escalar privilegios a root, tomando el control total del servidor.	Aplicar parches de seguridad de manera urgente. Actualizar el kernel del sistema operativo a una versión estable y soportada.

Análisis de Impacto

La explotación exitosa de las vulnerabilidades identificadas en My File Server 1 genera un impacto crítico sobre los tres pilares fundamentales de la seguridad de la información, según el modelo CIA (Confidencialidad, Integridad y Disponibilidad).

Confidencialidad — Comprometida (Impacto Alto):
El acceso inicial obtenido a través del servicio FTP, sumado a la posterior escalada de privilegios hasta la cuenta de root, permitió a los evaluadores acceder sin restricciones a la totalidad de los archivos almacenados en el servidor. Un atacante real habría podido exfiltrar información sensible de la organización, incluyendo documentos internos, credenciales de otros sistemas, bases de datos de clientes, contratos, información financiera y cualquier otro activo digital alojado en el equipo comprometido. La naturaleza del servidor —diseñado específicamente para el almacenamiento y distribución de archivos— agrava este impacto, ya que concentra información crítica de múltiples áreas de la empresa.

Integridad — Comprometida (Impacto Alto):
Con privilegios de root, un atacante tendría la capacidad de modificar, alterar o eliminar cualquier archivo del sistema sin dejar rastro evidente. Esto incluye la posibilidad de manipular registros financieros, alterar documentos oficiales, modificar configuraciones críticas del sistema operativo, o incluso implantar puertas traseras (backdoors) y mecanismos de persistencia que le permitieran mantener el acceso de forma indefinida. La integridad de la información almacenada en el servidor queda completamente en entredicho, ya que no existiría forma de garantizar que los datos no hayan sido alterados maliciosamente.

Disponibilidad—Comprometida(ImpactoAlto):
Un atacante con control total del sistema podría interrumpir los servicios de almacenamiento y distribución de archivos de manera deliberada, ya sea mediante el borrado de información crítica, la corrupción del sistema operativo, la instalación de ransomware, o la ejecución de ataques de denegación de servicio. La paralización de un servidor de archivos corporativo impacta directamente la operatividad de la organización, ya que los empleados no podrían acceder a los documentos necesarios para realizar sus funciones, los procesos internos se detendrían y la atención a clientes y socios comerciales se vería severamente afectada.

Impacto al Negocio:
Las consecuencias trascienden el ámbito técnico. La materialización de un ataque de esta naturaleza derivaría en pérdidas económicas significativas por concepto de recuperación de sistemas, interrupción de operaciones, posibles sanciones

regulatorias por incumplimiento de normativas de protección de datos, y costos legales asociados a la notificación de brechas a clientes y autoridades. Adicionalmente, el daño reputacional sería incalculable: la confianza de socios comerciales, clientes y accionistas se vería seriamente comprometida al evidenciarse que la organización no cuenta con controles de seguridad adecuados para proteger la información que le es confiada.

Conclusión

La evaluación de seguridad realizada sobre My File Server 1 revela un estado de exposición crítico que requiere atención inmediata por parte de la organización. La cadena de vulnerabilidades identificadas —credenciales expuestas en texto plano, configuraciones deficientes en los servicios de red, y un sistema operativo sin parches de seguridad actualizados— permitió a los evaluadores obtener el control total del servidor sin encontrar barreras técnicas significativas.

El principal hallazgo es que la organización carece de una gestión proactiva de vulnerabilidades y parches. El hecho de que un sistema operativo con una vulnerabilidad conocida y públicamente documentada desde 2016 (Dirty COW) permaneciera sin actualizar en producción demuestra una ausencia de controles básicos de mantenimiento de seguridad. Esta negligencia, combinada con prácticas inseguras como el almacenamiento de credenciales en archivos de texto plano accesibles vía web, configura un escenario propicio para que un atacante con motivación y recursos limitados pueda comprometer la totalidad de los activos alojados en el servidor.

La evidencia recolectada durante la fase de post-explotación confirma que el compromiso no se limitó a un acceso superficial, sino que alcanzó el nivel más alto de privilegios (root). Esto significa que la organización no solo perdió el control sobre su servidor de archivos, sino que cualquier información almacenada en él debe considerarse potencialmente comprometida. La organización debe asumir que, en un escenario real, los datos podrían haber sido extraídos, alterados o destruidos, y actuar en consecuencia.

Desde una perspectiva estratégica, este ejercicio evidencia la necesidad imperiosa de implementar un programa integral de seguridad que abarque, como

mínimo, la gestión continua de parches, la revisión periódica de configuraciones, la eliminación de credenciales expuestas, la implementación de autenticación multifactor y la segmentación adecuada de la red. La inversión en estas medidas paliativas resulta insignificante en comparación con el costo potencial de una brecha de seguridad real, que podría poner en riesgo la viabilidad operativa y financiera de la empresa.

En conclusión, My File Server 1 representa un riesgo inaceptable para la organización. La dirección debe priorizar la asignación de recursos humanos, técnicos y financieros para cerrar las brechas identificadas a la brevedad posible, estableciendo plazos concretos para la remediación y designando responsables claros para su ejecución. La seguridad de la información no es un gasto, sino una inversión indispensable para la continuidad del negocio y la preservación de la confianza de clientes, socios y accionistas.

Bibliografias

Nmap

Lyon, G. F. (2008). Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Insecure Press. https://nmap.org/book/

SMBMap

Evans, S. (n.d.). SMBMap - Samba Share Enumerator [Computer software]. GitHub. https://github.com/ShawnDEvans/smbmap

OWASP WSTG

OWASP Foundation. (n.d.). OWASP Web Security Testing Guide. https://owasp.org/www-project-web-security-testing-guide/

Vulnerabilidades

Dirty COW (CVE-2016-5195)

National Vulnerability Database. (2016). CVE-2016-5195: Race condition in mm/gup.c [Vulnerability record]. NIST. https://nvd.nist.gov/vuln/detail/CVE-2016-5195

Dirty COW (Análisis Técnico)

Oester, P. (2016). Dirty COW (CVE-2016-5195). https://dirtycow.ninja/